

Droit des données personnelles RGPD, cybersécurité & IA

Un cours pour comprendre, qualifier, sécuriser et décider
avant de mettre un projet numérique en production.

Fil rouge : SMARTCAMPUS AI

Ce que ce module va vous apprendre

1 Qualifier

Reconnaître une donnée personnelle, un traitement, un responsable, un sous-traitant.

2 Raisonner

Passer d'une opinion à une démonstration juridique structurée.

3 Auditer

Lire un projet numérique comme un risque juridique, cyber et organisationnel.

4 Sécuriser

Relier RGPD, architecture SI, habilitations, cloud et réponse à incident.

5 Décider

Formuler une recommandation : GO, GO sous conditions ou NO GO.

6 Débattre

IA, biométrie, tracking, recrutement, surveillance et mineurs.

Chapitres au programme

- Chapitre 1 — Fondamentaux du droit des données et du RGPD
- Chapitre 2 — Principes, bases juridiques, consentement et droits
- Chapitre 3 — Privacy by Design, cybersécurité et violations
- Chapitre 4 — Technologies actuelles : web, cloud, IA, biométrie, surveillance
- Chapitre 5 — Contrôles, sanctions, exposé et audit final SMARTCAMPUS AI

5 chapitres • 1 cas fil rouge



Pourquoi ce cours est central en 2026 ?

L
l'**20 150**

plaintes reçues par la CNIL en 2025

ent a

6 167

notifications de violations de données

83

sanctions prononcées en 2025

**486,8
M€**

d'amendes cumulées

2026 : la cybersécurité devient une priorité majeure de contrôle et de sanction.

FIL CONDUCTEUR

Ce qui est techniquement possible est-il forcément juridiquement autorisé ?

- Une technologie peut fonctionner... tout en étant disproportionnée.
- Une donnée peut être disponible... sans être librement exploitable.
- Un système peut être conforme sur le papier... mais dangereux techniquement.

CHAPITRE 1

Comprendre le droit des données et les fondamentaux du RGPD

Vocabulaire juridique, sources, données personnelles, traitements, acteurs et méthodologie.



Pourquoi protéger les données ?

€ Économie numérique

Les données alimentent services gratuits, publicité, personnalisation, IA, analyse de risque.

👁 Vie privée

Le croisement des informations permet de déduire habitudes, relations, santé, opinions.

! Sécurité

Une fuite de données peut toucher des milliers ou millions de personnes.

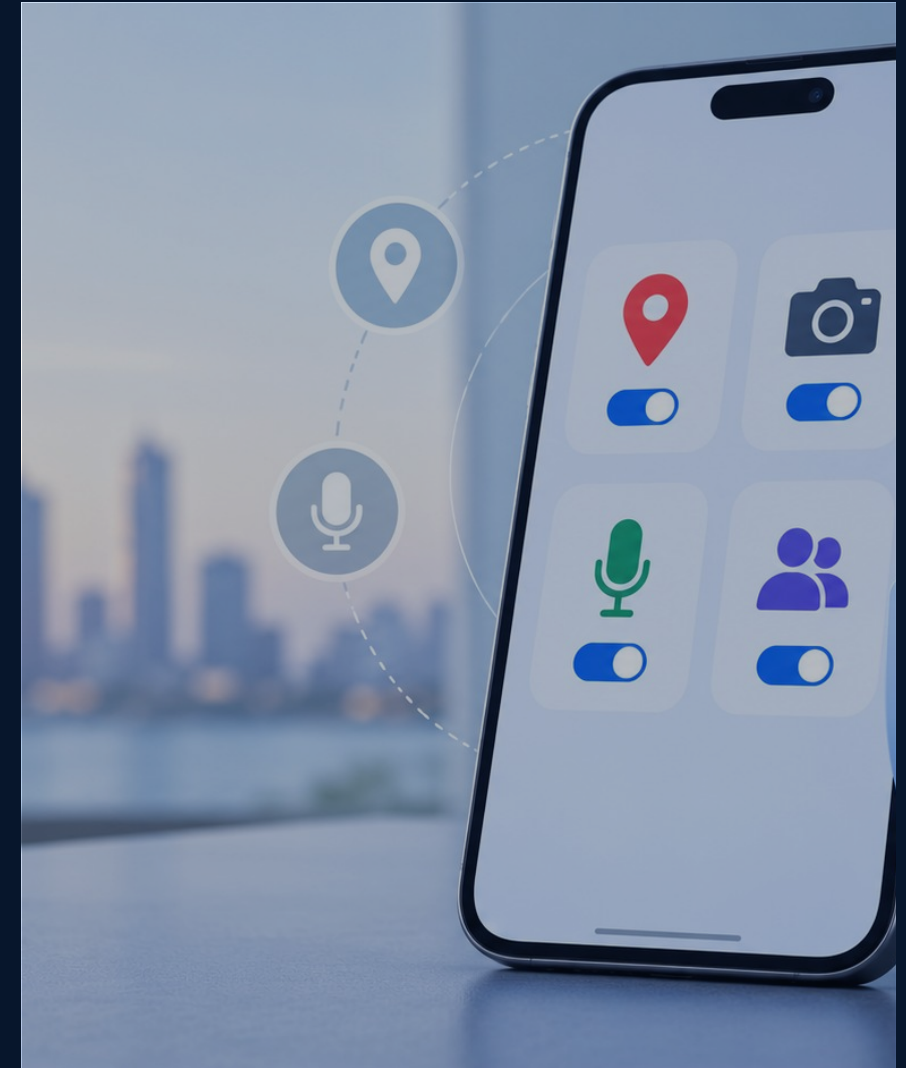
✓ Innovation responsable

Le RGPD n'interdit pas l'innovation : il impose justification, maîtrise et sécurité.

Vos données parlent de vous

- Smartphone : localisation, identifiants, permissions, historique d'applications
- Streaming : goûts, habitudes, horaires, préférences
- E-commerce : achats, adresse, moyens de paiement, paniers abandonnés
- Réseaux sociaux : interactions, relations, centres d'intérêt, photos
- Montre connectée : activité, sommeil, santé, rythme cardiaque

Activité d'ouverture : que peut-on déduire ?



8 min

Que savez-vous sur moi ?

Une plateforme possède vos recherches, déplacements, achats, interactions, sport, streaming et horaires. Que peut-elle déduire ?

1. Lister

les données disponibles

2. Déduire

les informations possibles

3. Classer

risque faible / fort

4. Débattre

utile ou intrusif ?

Vocabulaire juridique indispensable

Personne physique

Un individu : étudiant, salarié, client, utilisateur.

Personne morale

Organisation reconnue juridiquement : société, association, établissement.

Obligation

Comportement imposé par une règle de droit.

Responsabilité

Répondre juridiquement d'un acte ou d'un manquement.

Sanction

Conséquence du non-respect d'une règle.

Preuve

Élément permettant de démontrer conformité, consentement, sécurité, décision.

Sources du droit à connaître

Règlement européen

Directement applicable. Exemple : RGPD.

Directive

Objectif à transposer. Exemple : NIS2.

Loi nationale

Exemple : loi Informatique et Libertés.

Jurisprudence

Décisions des juridictions qui interprètent les règles.

Lignes directrices

Recommandations CNIL/CEPD utiles pour comprendre les attentes.

Contrats

Clauses sous-traitance, transferts, sécurité, confidentialité.

Institutions à connaître

CNIL

Autorité française : informe, accompagne, contrôle, sanctionne.

CEPD / EDPB

Coordonne l'application du RGPD entre autorités européennes.

CJUE

Interprète le droit de l'Union européenne.

Commission européenne

Élabore et applique de nombreux textes numériques européens.

Le RGPD en une phrase

- Règlement européen 2016/679, applicable depuis le 25 mai 2018
- Il protège les personnes physiques lorsque leurs données sont traitées
- Il responsabilise les organisations : elles doivent démontrer leur conformité
- Il s'applique aussi à certains acteurs hors UE lorsqu'ils ciblent ou suivent des personnes dans l'UE

GDPR = General Data Protection Regulation



Qu'est-ce qu'une donnée personnelle ?

Identifiée

La personne est directement reconnue : nom, prénom, photo, email nominatif.

Identifiable

La personne peut être retrouvée par recoupement : IP, cookie, GPS, identifiant.

Important

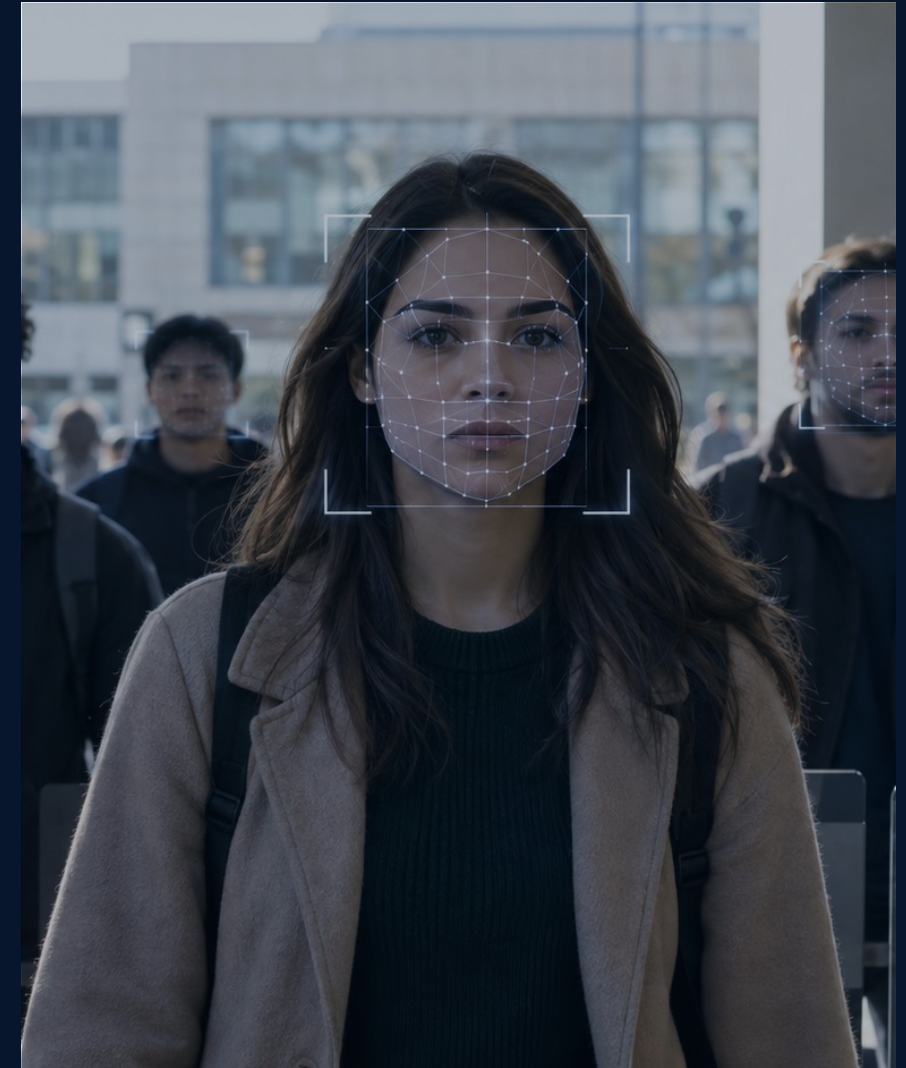
Une donnée technique peut être une donnée personnelle, même sans nom/prénom.

Donnée personnelle ou non ?

Information	Qualification	Pourquoi ?
Nom + prénom	Oui	identification directe
Adresse IP	souvent oui	identification indirecte possible
Température extérieure	non	ne concerne pas une personne
Numéro étudiant	oui	rattaché à une personne
USER_12491	potentiellement oui	réidentification possible
Statistique anonyme	non	si aucune personne identifiable

Données sensibles : niveau de risque renforcé

- Santé, génétique, biométrie aux fins d'identification
- Origine raciale ou ethnique, religion, opinions politiques
- Vie sexuelle, orientation sexuelle, appartenance syndicale
- Principe : traitement interdit sauf exception prévue par le RGPD
- Question réflexe : existe-t-il une alternative moins intrusive ?



DÉBAT

La reconnaissance faciale sur un campus : sécurité renforcée ou surveillance excessive ?

- Le badge est-il suffisant ?
- Quel risque pour les étudiants ?
- Le gain pratique justifie-t-il la biométrie ?

Anonymisation ≠ pseudonymisation

Anonymisation

La personne ne peut plus raisonnablement être identifiée. Les données peuvent sortir du champ RGPD.

Pseudonymisation

L'identité est remplacée par un identifiant, mais un lien reste possible. Le RGPD continue.

Risque

Croiser plusieurs jeux de données peut permettre une réidentification.

Qu'est-ce qu'un traitement ?

- Collecter, enregistrer, stocker, consulter, modifier
- Analyser, rapprocher, profiler, transmettre
- Archiver, supprimer, détruire
- Un simple fichier Excel avec noms + emails est déjà un traitement
- Le stockage est lui-même un traitement

Erreur fréquente : “on stocke juste”

Les acteurs du RGPD

Personne concernée

La personne dont les données sont traitées.

Responsable du traitement

Celui qui décide pourquoi et comment les données sont utilisées.

Sous-traitant

Celui qui traite les données pour le compte du responsable.

DPO

Conseille, accompagne, contrôle la conformité et dialogue avec la CNIL.

Accountability : la conformité doit se prouver

- Registre des traitements
- Procédures internes
- Contrats de sous-traitance
- Preuves de consentement lorsqu'il est utilisé
- Analyses d'impact et de risques
- Mesures de sécurité documentées
- Traçabilité des décisions



Méthodologie du cas pratique juridique



12 min

Appliquer la méthode

Une application collecte la géolocalisation 24 h/24 pour proposer des restaurants à proximité.

1. Faits

ce qui est utile

2. Qualification

donnée + traitement

3. Problème

question juridique

4. Règle

principe applicable

5. Application

analyse concrète

6. Conclusion

réponse motivée

À maîtriser à la fin du chapitre 1



donnée personnelle



donnée sensible



traitement



personne concernée



responsable du traitement



sous-traitant



finalité



anonymisation



pseudonymisation



accountability



proportionnalité



méthode juridique

CHAPITRE 2

Collecter et exploiter des données

Principes de l'article 5, bases juridiques, consentement, information et droits des personnes.



Article 5 : le cœur du RGPD

Licéité

Un traitement doit reposer sur une base juridique.

Loyauté

Ne pas tromper la personne sur l'usage réel.

Transparence

Expliquer clairement qui fait quoi, pourquoi et combien de temps.

Finalité

Un objectif précis : pas "au cas où".

Minimisation

Limiter aux données réellement nécessaires.

Sécurité

Assurer intégrité et confidentialité.

Finalité : pourquoi cette donnée ?

- Chaque donnée doit correspondre à un objectif déterminé
- Une finalité vague ne suffit pas : “améliorer nos services” ne justifie pas tout
- Une donnée collectée pour un compte utilisateur ne peut pas être réutilisée librement pour publicité, scoring ou IA
- Réflexe : écrire la finalité avant de créer le champ en base

Question réflexe : pourquoi ?

Minimisation : moins collecter, mieux protéger

- Application météo : GPS utile, mais contacts et microphone difficiles à justifier
- Formulaire d'inscription : demander uniquement ce qui est nécessaire
- Logs : utiles pour sécurité, mais attention à la durée et aux accès
- IA : une base massive n'est pas automatiquement proportionnée



15 min

Audit express : FIT360

L'application sportive collecte nom, âge, GPS permanent, poids, rythme cardiaque, sommeil, contacts et historique Internet. Tout est conservé sans limite.

1. Identifier

données sensibles

2. Vérifier

minimisation

3. Lister

finalités

4. Proposer

données à supprimer

5. Fixer

durées

6. Sécuriser

accès et mesures

Les bases juridiques de l'article 6

Consentement

Acceptation libre, spécifique, éclairée et univoque.

Contrat

Nécessaire à l'exécution d'un contrat.

Obligation légale

Traitement imposé par un texte.

Intérêt vital

Protection de la vie ou de l'intégrité.

Mission d'intérêt public

Certaines missions publiques.

Intérêt légitime

Analyse en balance avec les droits de la personne.

Erreur classique : le consentement ne règle pas tout

- Le RGPD n'impose pas le consentement pour chaque traitement
- "J'accepte les CGU" ne vaut pas consentement global pour tout
- Le consentement doit pouvoir être retiré aussi simplement qu'il a été donné
- Certaines opérations reposent plutôt sur le contrat ou l'obligation légale

À retenir : consentement ≠ joker

Quelle base juridique ?

Situation	Base possible	Pourquoi
Livrer une commande	Contrat	nécessaire à la livraison
Conserver une facture	Obligation légale	exigence comptable/fiscale
Newsletter commerciale	Consentement souvent	choix marketing distinct
Sécurité d'un bâtiment	Intérêt légitime possible	analyse de proportionnalité
Paie salarié	Contrat / obligation	gestion RH et obligations
Sauvegarde vitale	Intérêt vital	situation exceptionnelle

Intérêt légitime : pas un joker

- 1. L'intérêt poursuivi est-il réel et légitime ?
- 2. Le traitement est-il nécessaire pour atteindre cet objectif ?
- 3. Les droits, libertés et attentes raisonnables des personnes ne prévalent-ils pas ?
- Exemple : sécurité, prévention de la fraude, certains logs

Test en 3 temps

Information des personnes : ce qu'il faut expliquer

- Identité du responsable du traitement
- Finalités et bases juridiques
- Catégories de données et destinataires
- Durées de conservation
- Droits des personnes et modalités d'exercice
- Transferts éventuels hors EEE
- Possibilité de saisir la CNIL



INTERFACE ET CONSENTEMENT

Peut-on considérer qu'un consentement est libre si le bouton “Accepter” est énorme et “Refuser” presque invisible ?

- Le design peut orienter le comportement.
- Les dark patterns transforment parfois un choix en illusion de choix.
- La transparence passe aussi par l'interface.



Les droits des personnes

Information

Comprendre le traitement avant ou au moment de la collecte.

Accès

Demander quelles données sont détenues.

Rectification

Corriger une donnée inexacte.

Effacement

Demander la suppression dans certains cas.

Opposition

Refuser certains traitements.

Portabilité

Récupérer certaines données dans un format réutilisable.

Droit à l'effacement : problème d'architecture SI

- Un DELETE en base ne suffit pas toujours
- Les données peuvent exister dans CRM, logs, backups, data warehouse, analytics, exports
- Certaines données peuvent être conservées pour obligation légale ou preuve
- Il faut prévoir des procédures : actif, archive, sauvegarde, prestataires

“Supprimez mon compte” ≠ une seule table SQL

10 min

Cartographier l'effacement

Un utilisateur demande : “supprimez tout ce que vous avez sur moi”. Où chercher ?

1. Base prod

2. CRM

3. Logs

4. Backups

5. Prestataires

6. Exports

Profilage et décisions automatisées

- Profilage : évaluer préférences, comportement, risque, performance, solvabilité
- Décision automatisée : décision prise sans intervention humaine significative
- Effets possibles : crédit, assurance, emploi, accès à un service
- Article 22 : protection spécifique dans certains cas



DÉBAT

Une IA doit-elle pouvoir éliminer automatiquement un candidat à un emploi ?

- Données utilisées : CV, voix, vidéo, LinkedIn, tests, comportement.
- Risques : biais, opacité, décision significative, discrimination.
- Solution : transparence, intervention humaine, minimisation, audit.

À maîtriser à la fin du chapitre 2



principes de l'article 5



les six bases juridiques



intérêt légitime



droits des personnes



profilage



finalité et minimisation



consentement valable



information claire



effacement et architecture SI



décision automatisée

CHAPITRE 3

Concevoir et sécuriser un système conforme

Privacy by Design, registre, AIPD, sous-traitants, sécurité, violations et incident response.

Privacy by Design : la conformité commence avant le code



Privacy by Design : mauvais réflexe / bon réflexe

Mauvais réflexe

Développer → collecter massivement → mettre en production → appeler le DPO après incident.

Bon réflexe

Définir finalité, minimisation, base juridique, sécurité, durées et droits dès la conception.

Pour un dev

Chaque champ, chaque log, chaque permission et chaque API doit avoir une justification.

Privacy by Default : protéger par défaut

- Profil privé plutôt que public par défaut
- Géolocalisation désactivée sauf nécessité claire
- Publicité personnalisée non activée automatiquement
- Partage de données limité au strict nécessaire
- Options de confidentialité compréhensibles



Applications mobiles : actualisation CNIL 2025

- Permissions : caméra, micro, contacts, localisation doivent être justifiées
- SDK : attention aux données envoyées à des tiers
- Minimisation : limiter permissions, données, durées
- Privacy by Design : intégrer la protection dès la conception
- Autorisation OS $\neq$ base juridique RGPD

Actualité 2025

Registre des traitements : cartographeur pour maîtriser

Traitement

Nom clair : gestion étudiants, newsletter, support, paie, sécurité.

Finalité

Pourquoi ce traitement existe.

Données

Catégories utilisées : identité, logs, santé, paiement.

Destinataires

Qui reçoit ou accède aux données.

Durée

Combien de temps conserver.

Sécurité

Mesures techniques et organisationnelles.

AIPD / DPIA : quand le risque devient élevé

- Analyse d'impact relative à la protection des données
- À envisager pour surveillance, biométrie, scoring, IA, données sensibles, grande échelle
- Objectif : vérifier nécessité, proportionnalité, risques et mesures de réduction
- Elle doit être faite avant le déploiement, pas après le scandale



20 min

Mini-AIPD : recrutement vidéo

Une IA analyse la voix et les expressions faciales des candidats pour produire un score automatique.

1. Nécessité

pourquoi ?

2. Proportionnalité

moins intrusif ?

3. Risques

droits/libertés

4. Mesures

réduction

5. Transparence

information

6. Décision

go/no go

Sous-traitance : le cloud ne transfère pas toute la responsabilité

- Le responsable doit choisir un prestataire offrant des garanties suffisantes
- Le contrat doit encadrer instructions, sécurité, confidentialité, assistance, audits
- Il faut suivre les sous-traitants ultérieurs
- Un incident chez le prestataire peut devenir votre incident



Article 32 : sécurité des traitements

Techniques

MFA, chiffrement, hachage, segmentation, sauvegardes, logs, patching, sécurité API.

Organisationnelles

Politique d'habilitation, revues d'accès, formation, gestion incidents, audits.

Adaptées au risque

La sécurité attendue dépend de la sensibilité, de l'échelle et des conséquences.

Moindre privilège : question d'examen

- Un développeur stagiaire a-t-il besoin d'un accès admin permanent à toute la base de production ?
- Risque : exfiltration, erreur, modification, confidentialité, absence de traçabilité
- Réponse attendue : accès limité, temporaire, justifié, journalisé, revu périodiquement

Principe : need to know / least privilege

Violation de données : 3 dimensions

Confidentialité

Données divulguées ou consultées sans autorisation.

Intégrité

Données modifiées ou altérées de manière non autorisée.

Disponibilité

Données perdues, détruites ou indisponibles.

Réagir à un incident



Le délai de 72 heures

- Si la violation présente un risque pour les droits et libertés, notification à l'autorité dans les meilleurs délais, si possible sous 72 heures
- 72 heures ne signifie pas que toute l'enquête est terminée
- La notification peut être complétée lorsque les investigations progressent
- Tout doit être documenté

Réflexe incident : documenter

Pourquoi ce cours est central en 2026 ?

L
l'

20 150

plaintes reçues par la CNIL en 2025

ent a

6 167

notifications de violations de données

83

sanctions prononcées en 2025

**486,8
M€**

d'amendes cumulées

2026 : la cybersécurité devient une priorité majeure de contrôle et de sanction.

20 min

Atelier incident : base exfiltrée

Vendredi 17 h 30 : un attaquant exfiltre 500 000 emails, noms, téléphones, mots de passe hachés et historiques de commandes.

1. Urgence

contenir

2. Équipe

qui mobiliser ?

3. Preuves

quoi conserver ?

4. Risque

pour personnes

5. Notifier

CNIL ?

6. Informer

utilisateurs ?

À maîtriser à la fin du chapitre 3



Privacy by Design



Privacy by Default



registre des traitements



AIPD / DPIA



sous-traitance



article 32



moindre privilège



violation de données



72 heures



réponse à incident

CHAPITRE 4

RGPD et technologies contemporaines

Cookies, tracking, cloud, transferts, IA, AI Act, biométrie, recrutement, surveillance et mineurs.

Cookies et traceurs : tous ne se valent pas

- Authentification et panier : souvent nécessaires au service
- Mesure d'audience : dépend des conditions et du paramétrage
- Publicité comportementale : consentement souvent central
- Fingerprinting : traçage plus invisible et intrusif
- Le design du choix est une question juridique

Web = données + interface + consentement

Dark patterns : le droit dans l'interface

Bouton “Accepter” dominant

Visuellement mis en avant pour orienter le choix.

Refus caché

Plusieurs clics ou formulation ambiguë.

Case précochée

Le consentement doit être actif et univoque.

Fatigue du consentement

L'utilisateur clique pour accéder vite au service.

DÉBAT

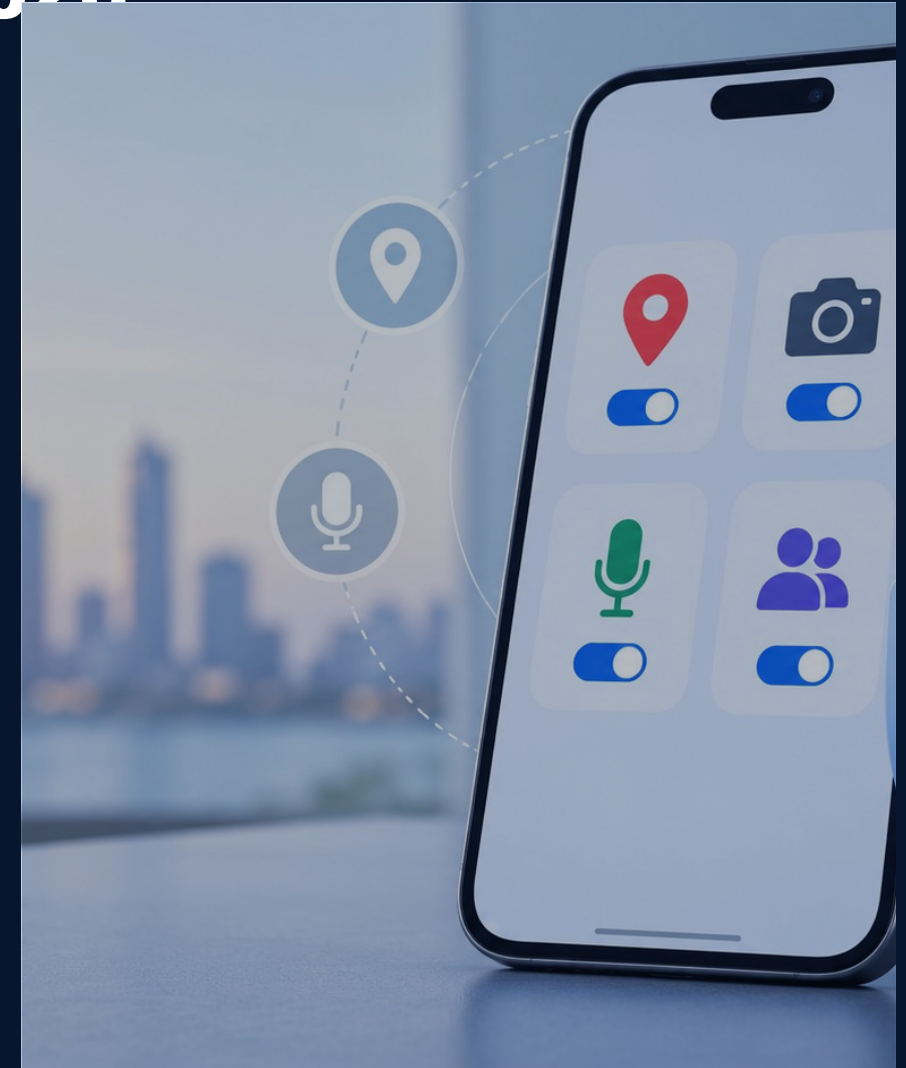
Le consentement aux cookies est-il encore réellement libre ?

- L'utilisateur veut lire le contenu rapidement.
- Le refus peut être plus difficile que l'acceptation.
- Le modèle économique dépend parfois du tracking.



Tracking multi-terminaux : enjeu 2026

- Un choix peut être synchronisé entre ordinateur, smartphone, tablette, TV connectée
- Avantage : cohérence de l'expérience utilisateur
- Risque : généralisation du suivi et manque de contrôle
- Question : retrait aussi simple que l'acceptation ?



Cloud : questions à poser avant de signer

- Où les données sont-elles hébergées ?
- Qui peut y accéder ?
- Quels sous-traitants ultérieurs ?
- Existe-t-il des transferts hors EEE ?
- Quelles garanties contractuelles ?
- Quelles mesures de sécurité ?
- Que prévoit le contrat en cas d'incident ?



Transferts internationaux : hors EEE ≠ interdit, mais encadré

- Décision d'adéquation
- Clauses contractuelles types
- Garanties appropriées
- Analyse du contexte et des lois applicables
- Information des personnes lorsque nécessaire

Question : où part réellement la donnée ?

15 min

Cas API IA externe

Votre application envoie des conversations d'étudiants vers une API d'IA située hors UE.

1. Données

envoyées ?

2. Finalité

pourquoi ?

3. Entraînement

utilisées ?

4. Conservation

durée ?

5. Transfert

hors EEE ?

6. Information

étudiants ?

IA : priorité stratégique 2025-2028

- La CNIL place l'IA parmi ses axes majeurs 2025-2028
- Enjeux : données d'entraînement, transparence, droits, sécurité, biais, réidentification
- Une IA peut être utile, mais elle doit être juridiquement analysée comme tout traitement de données
- Le RGPD et l'AI Act peuvent s'appliquer ensemble



Avant d'entraîner une IA : 8 questions

- D'où viennent les données ?
- S'agit-il de données personnelles ?
- Les personnes pouvaient-elles s'attendre à cet usage ?
- Quelle base juridique ?
- Toutes les données sont-elles nécessaires ?
- Des données sensibles sont-elles présentes ?
- Peut-on exercer les droits ?
- Le modèle peut-il restituer des données ?

Entraînement IA = traitement à analyser

Une donnée publique n'est pas forcément libre

- Une photo publique sur Internet reste une donnée personnelle si la personne est identifiable
- Le scraping massif doit être juridiquement analysé
- La finalité initiale de publication ne justifie pas n'importe quelle réutilisation
- Les attentes raisonnables des personnes comptent

Public ≠ libre

Un modèle d'IA peut-il être anonyme ?

- Pas automatiquement, même s'il ne contient pas une table classique
- Il faut évaluer la probabilité d'extraire ou d'obtenir des données personnelles par requêtes
- Certains modèles sont conçus pour reproduire des personnes : voix, visage, informations personnelles
- L'analyse est au cas par cas



RGPD ≠ AI Act

RGPD

Protège les personnes lorsque leurs données personnelles sont traitées.

AI Act

Encadre les systèmes et modèles d'IA selon leurs usages et leurs risques.

Ensemble

Un chatbot RH peut être soumis aux deux textes en même temps.

Calendrier AI Act à retenir

Date	Ce qui devient applicable	Intérêt pour ESGI
2 février 2025	Premières dispositions : usages interdits, culture IA	savoir repérer les IA problématiques
2 août 2025	Règles sur modèles IA à usage général	LLM, fournisseurs, documentation
2 août 2026	Application large + transparence art. 50	chatbots, deepfakes, contenu IA, biométrie

Transparence IA : obligations 2026

- Informer lorsqu'une personne interagit directement avec certains systèmes d'IA
- Marquage/détection de certains contenus générés ou manipulés artificiellement
- Information sur deepfakes
- Information en cas de reconnaissance émotionnelle ou catégorisation biométrique
- Objectif : éviter tromperie, manipulation et confusion humain/machine



Recrutement algorithmique : cas RecruitAI

- CV, voix, expression faciale, LinkedIn, temps de réponse
- Score : 79/100 “à recevoir” ou 38/100 “rejet automatique”
- Questions : profilage ? décision automatisée ? données biométriques ? biais ? transparence ?
- La CNIL a retenu le recrutement comme thématique prioritaire de contrôle 2026



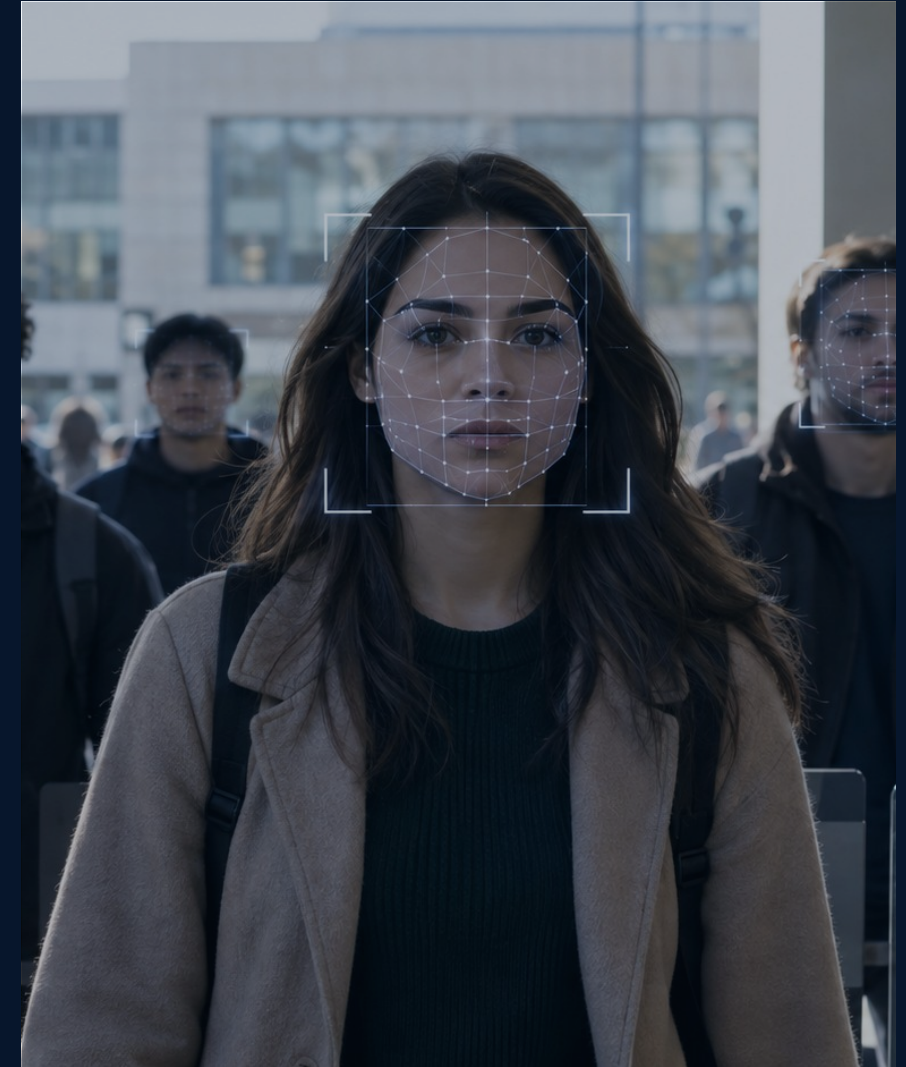
Surveillance des salariés : limite à ne pas franchir

- Ordinateur professionnel $\neq$ surveillance illimitée
- Emails, logs, sites visités, captures écran, GPS, webcam, productivité : toujours proportionnalité
- La surveillance permanente est très sensible
- En 2025, la vidéosurveillance des salariés a été un sujet majeur de sanctions CNIL

Travail + données = vigilance renforcée

Biométrie : confort ou intrusion ?

- Empreinte digitale, reconnaissance faciale, reconnaissance vocale
- Données biométriques utilisées pour identifier une personne : régime renforcé
- Question centrale : existe-t-il une alternative moins intrusive ?
- Exemples campus : accès bâtiment, présence, session informatique, paiement



Mineurs et numérique

- Réseaux sociaux, jeux, géolocalisation, recommandations, publicité, données scolaires
- La CNIL a placé les mineurs parmi les axes stratégiques 2025–2028
- Enjeu : compréhension, consentement, exposition, durée, profilage

Protection renforcée

À maîtriser à la fin du chapitre 4



cookies et traceurs



dark patterns



cloud et sous-traitance



transferts internationaux



données publiques et scraping



IA et données d'entraînement



modèle IA et anonymat



RGPD vs AI Act



transparence IA 2026



recrutement algorithmique



biométrie



surveillance salariés

Contrôler, réagir et décider

CNIL, sanctions, exposés, grille d'évaluation et audit final
SMARTCAMPUS AI.

La CNIL ne fait pas que conseiller

- Elle reçoit des plaintes et signalements
- Elle peut contrôler sur place, en ligne, sur pièces ou sur audition
- Elle peut mettre en demeure, ordonner des mesures et sanctionner
- Les contrôles 2026 ciblent notamment le recrutement, et la cybersécurité est un axe majeur



Bilan sanctions 2025

259 décisions correctrices

Sanctions, mises en demeure, rappels, avertissements.

83 sanctions

Décisions prononcées en 2025.

143 mises en demeure

Exiger la mise en conformité.

486,8 M€

Montant cumulé inédit des amendes.

Sujets majeurs

Cookies, surveillance salariés, sécurité des données.

Sécurité

Mots de passe faibles, comptes partagés, habilitations.

Sanctions maximales du RGPD

- Selon la catégorie de manquement : jusqu'à 20 millions d'euros
- Ou jusqu'à 4 % du chiffre d'affaires annuel mondial
- Mais le risque n'est pas seulement financier : réputation, perte de confiance, contentieux, incident cyber
- Un bon dossier de conformité montre aussi les efforts et décisions prises

Sanction = droit + confiance + réputation

Le DPO : rôle et limites

- Le DPO conseille, accompagne, sensibilise et contrôle
- Il dialogue avec la CNIL et les métiers
- Il ne prend pas toute la responsabilité à la place de l'organisation
- Les équipes IT restent essentielles : architecture, sécurité, logs, accès, sauvegardes

DPO + IT + métiers = conformité réelle

SMARTCAMPUS AI

La direction veut lancer la plateforme lundi. Votre équipe doit décider : GO, GO sous conditions ou NO GO.



Fonctionnalités

planning, messagerie, paiement, chatbot, IA pédagogique, géolocalisation, reconnaissance faciale



Données

identité, photo, notes, absences, localisation, paiements, messages, conversations chatbot



Architecture

mobile, cloud, API IA externe, CRM, analytics, backups, data warehouse, logs

Question finale : pouvez-vous autoriser la mise en production ?

SMARTCAMPUS AI — données collectées

- Identité : nom, prénom, email, téléphone, photo
- Scolarité : notes, absences, résultats, orientation
- Activité : logs, historique navigation, messagerie, chatbot
- Localisation : présence campus, géolocalisation mobile
- Sensibles possibles : santé, biométrie, conversations personnelles

Étape 1 : cartographier

SMARTCAMPUS AI — traitements à qualifier

- Contrôle d'accès par reconnaissance faciale
- Prédiction du décrochage scolaire
- Recommandation de formations
- Chatbot pédagogique
- Messagerie et suivi des interactions
- Paiement et facturation
- Analytics et amélioration du service

Étape 2 : finalités + bases juridiques

SMARTCAMPUS AI — points de risque

- Biométrie : nécessité et alternative ?
- IA : profilage, transparence, décision automatisée ?
- Cloud/API externe : transferts, sous-traitance, sécurité ?
- Données santé dans le chatbot : détection et protection ?
- Durées : conservation limitée et justifiée ?
- Accès : admin production, logs, moindre privilège ?

Étape 3 : risques majeurs

45 min

Audit final en équipe

Décidez si SMARTCAMPUS AI peut être lancé lundi : GO, GO sous conditions ou NO GO.

1. Cartographier

données

2. Qualifier

risques

3. Justifier

bases

4. Sécuriser

mesures

5. Documenter

preuves

6. Décider

GO/NO GO

Exposé étudiant : objectif

- Vous ne devez pas réciter le RGPD
- Vous devez analyser une technologie actuelle
- Vous devez utiliser un cas réel récent
- Vous devez relier droit + informatique + risques + solutions
- Vous devez prendre position et ouvrir un débat

12 min + 5 min questions

Sujets possibles d'exposés

IA générative

LLM, scraping, confidentialité, données d'entraînement.

Reconnaissance faciale

Biométrie, campus, surveillance, proportionnalité.

Ransomware

Violation de données, notification, responsabilité, cybersécurité.

Cookies

Dark patterns, tracking, publicité comportementale.

Cloud

Transferts, sous-traitants, sécurité, souveraineté.

Recrutement IA

Profilage, décision automatisée, biais, transparence.

Plan obligatoire de l'exposé



Actualité 2025–2026 obligatoire dans l'exposé

- Exemples acceptés : sanctions CNIL 2025
- Contrôles prioritaires CNIL 2026
- Recommandations mobiles 2025
- Recommandations CNIL IA 2025
- Avis EDPB IA modèles 2024
- AI Act et transparence 2026
- Violation de données récente analysée sérieusement

Pas d'exposé purement théorique

Grille d'évaluation de l'exposé

Critère	Points	Attendu
Maîtrise du sujet	/3	clair, précis, problématisé
Vocabulaire juridique	/2	termes RGPD exacts
Analyse juridique	/4	règles + application
Compréhension technique	/3	fonctionnement réel
Actualisation	/2	2025-2026 sourcée
Solutions	/2	techniques + juridiques
Oral + réponses	/4	support, aisance, débat

Les 15 mots à maîtriser



donnée personnelle



traitement



base juridique



responsable du traitement



minimisation



Privacy by Design



profilage



violation de données



donnée sensible



finalité



consentement



sous-traitant



accountability



pseudonymisation



AIPD

Les 10 questions du professionnel



Quelle donnée utilisons-nous ?



Pourquoi ?



En avons-nous réellement besoin ?



Sur quelle base juridique ?



L'utilisateur est-il informé ?



Combien de temps la conservons-nous ?



Qui y accède ?



Comment la protégeons-nous ?



Que faisons-nous en cas de fuite ?



Pouvons-nous démontrer nos choix ?

MESSAGE FINAL

Technically possible does not mean legally permitted.

- Et l'inverse est vrai : une conformité juridique sans sécurité technique n'est pas une véritable protection des données.
- Le RGPD concerne votre code, vos bases, vos API, vos logs, votre cloud, votre IA et vos droits d'accès.



Sources principales du module

- RGPD — Règlement (UE) 2016/679
- CNIL — Rapport annuel 2025, bilan sanctions 2025, contrôles prioritaires 2026
- CNIL — Plan stratégique 2025-2028, recommandations applications mobiles 2025
- CEPD / EDPB — Avis sur les modèles d'IA et le RGPD
- AI Act — Règlement (UE) 2024/1689 et lignes directrices article 50
- Les sources détaillées sont intégrées en notes des diapositives concernées

À citer dans les exposés